

File No.: PS/00274/2022

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on January 12, 2022. The complaint is directed against the CITY COUNCIL OF BURGOS with NIF P0906100C (hereinafter, the City Council). The reasons for the complaint are as follows:

The complainant states that the City Council sent him a communication regarding a traffic violation without taking the measures that guarantee the confidentiality of his data.

He claims that when the receipt, which remains with the notifying company, is removed, part of the content becomes visible: fine amount, violation, vehicle registration, date of the events, and photograph of the vehicle. This content can be seen by the notifying agent when removing the receipt attached to the letter. Furthermore, he indicates that the front side contains the data of the owner of the reported vehicle (Name, address, and locality). And those of the sender, Local Police administrative section.

The complainant believes that the individuals who notify the resolution or who may take charge of it can access all the previously mentioned data.

Along with the notification, two photographs are provided, one of the front and another of the back of the document used to communicate the report of the traffic violation allegedly committed on 11/13/21.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), the complaint was forwarded to the City Council for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on March 8, 2022, as evidenced by the acknowledgment of receipt in the file.

No response has been received to this forwarding letter.

2/11

THIRD: On April 12, 2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: On March 30, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the respondent for the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR.

FIFTH: The aforementioned initiation agreement was notified on March 30, 2023, in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), and after the period granted for the submission of allegations had elapsed, it was confirmed that no allegations had been received from the respondent. Article 64.2.f) of the LPACAP - a provision of which the respondent was informed in the initiation agreement - establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the responsibility attributed, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts that constituted the accusation, the infringement of the GDPR attributed to the respondent, and the sanction that could be imposed. Therefore, considering that the respondent has not made allegations against the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

In view of all that has been acted upon by the Spanish Agency for Data Protection in this procedure, the following facts are considered proven,

PROVEN FACTS

FIRST: That the complainant received a notification from the City Council of Burgos, of which he provides two images along with the complaint. As can be verified in these images, on one hand, on the front of the letter, in addition to the recipient, the postage of the shipment is indicated, which determines that it is the exterior part of the letter and that it was not inside an envelope, and on the other hand, on the back, the content of the notified document can be seen.

SECOND: That once the notifier removed the acknowledgment of receipt from the notification, the following data from the content of the document became exposed: fine amount, violation, vehicle registration, date of the events, and photograph of the vehicle. Furthermore, on the front side, the data of the owner of the reported vehicle (Name, address, and locality) appears, as well as those of the sender, Local Police administrative section.

LEGAL GROUNDS

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/11

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In the present case, in accordance with the provisions of Article 4.1 of the GDPR, it is established that there is a processing of personal data, given that the City Council of Burgos, in its relations with citizens, carries out various processing activities, including the processing of administrative sanctioning procedures in the area of Traffic and the notification of documents, which involves the organization, consultation, use, and communication of, among others, the following personal data of individuals: name, surname, address, and vehicle registration, understanding personal data as: "any information relating to an identified or identifiable natural person."

The City Council of Burgos carries out this activity in its capacity as the data controller, as it is the entity that determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR, which defines the "data controller" or "controller" as: "the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its appointment may be established by the law of the Union or of the Member States."

An identifiable natural person is considered to be one whose identity can be determined, directly or indirectly, in particular by means of an identifier, such as a name, identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.

Furthermore, processing must be understood as "any operation or set of operations performed on personal data or sets of personal data, whether or not by automated means."

4/11

by automated or non-automated procedures, such as collection, recording, organization, structuring, storage, adaptation or modification, extraction, consultation, use, communication by transmission,

dissemination or any other form of enabling access, comparison or interconnection, limitation, deletion or destruction.

For its part, Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss or alteration of personal data transmitted, stored or otherwise processed, or to unauthorized communication or access to such data."

In this case, the technical and organizational measures adopted by the City Council to safeguard the confidentiality of the personal data it holds do not guarantee an adequate level of security relative to the risk, due to the design of the notification of the document pertaining to a sanctioning procedure in traffic matters, since the data regarding the infraction committed by the citizen is on the external part of the letter, and when the notifying agent removes the acknowledgment of receipt, the personal data of the interested party to whom the letter is addressed is exposed to anyone.

The data affected by the detected breach were: infraction, penalty amount, vehicle registration, date of the events, and photograph of the vehicle. Additionally, this data may be related to the name, surname, and address of the recipient of the notification that appears in the notice.

The security of personal data is regulated in Article 32 of the GDPR, which establishes the security of processing.

III

Security of Processing

Article 32 "Security of Processing" of the GDPR states:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which shall include, where appropriate, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data promptly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/11

2. When the responsible parties or data processors listed in section 1 commit any of the violations referred to in articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the violation that has been committed. The resolution shall be notified to the responsible party or data processor, to the hierarchical body to which they belong, if applicable, and to the affected individuals who have the status of interested parties, if applicable.

3. Without prejudice to what is established in the previous section, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on the disciplinary or sanctioning regime that is applicable.

Furthermore, when the violations are attributable to authorities and executives, and it is demonstrated that there are technical reports or recommendations for processing that have not been duly addressed, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the Official State Bulletin or the corresponding regional bulletin.

4. The resolutions related to the measures and actions referred to in the previous sections must be

communicated to the data protection authority.

5. The actions taken and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities. The facts referred to above demonstrate the lack of appropriate technical and organizational measures to ensure a level of security adequate to the risk, as they allow the display of personal data of the recipient of the notification of a sanctioning procedure in traffic matters, which constitutes a lack of minimum diligence by the responsible party, allowing the display of the data to third parties unrelated to the interested party. The City Council of Burgos, as the data controller, must implement the means and measures so that all its personnel are aware of and comply with the responsibilities in handling personal data, with access to the content of the document limited to assigned personnel, both during the time of its dispatch and thereafter.

In this case, because the data regarding the violation committed by the citizen is located on the external part of the letter, when the notifying agent removed the delivery receipt attached to it, the data of the sanctioning procedure that was subject to notification became exposed to anyone: violation, sanction amount, vehicle registration, date of the events, and photograph of the vehicle.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/11

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather states that the data controller and the data processor shall apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of the technical and organizational measures must be made considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, and the process of verification (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by the processing of data, as a consequence of the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the risks inherent in the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly those that may cause physical, material, or immaterial harm.”

Recital 75 of the GDPR lists a series of factors or situations associated with risks to the guarantees of the rights and freedoms of the data subjects:

“The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing could lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases

where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/11

or philosophical beliefs, union membership, and the processing of genetic data, health-related data, or data concerning sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, particularly the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects.”

The responsibility of the City Council is determined by the lack of security measures, as it is responsible for making decisions aimed at effectively implementing appropriate technical and organizational measures to ensure a level of security appropriate to the risk, to ensure that the data is not visible to anyone receiving the shipment. In the absence of a physical element that prevents or reveals unauthorized access to the content of the postal communication, personal data remains unprotected.

In this regard, Recital 74 of the GDPR establishes that:

"The controller's responsibility must be established for any processing of personal data carried out by themselves or on their behalf. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons."

Translating these considerations to the specific case being examined, it can be concluded that, at the time of the shipment, the City Council did not have reasonable security measures in place based on the estimated potential risks, since the fact that personal data related to the traffic violation is left on the external part of the document sent makes the data accessible, not only to the notifying agent who retrieves the acknowledgment of receipt but also to any other person who may physically handle the letter, such as in the case where the notification is delivered to a person other than the recipient who is at their home, as permitted by Article 42.2 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations; even before the shipment is made, any employee of the City Council of Burgos who has unauthorized access to the document without the acknowledgment of receipt attached could consult the data.

In accordance with the evidence available in this resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement, attributable to the respondent, for violation of Article 32 of the GDPR.

IV

Classification and qualification of the infringement of Article 32 of the GDPR

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/11

In accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the City Council of Burgos does not have appropriate measures in place according to the risk to prevent the data of citizens contained in the notifications, such as the one that is the subject of this procedure, from being improperly exposed to third parties.

The known facts constitute an infringement, attributable to the City Council, classified under Article

83.4 of the GDPR, which stipulates the following:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations for infringements, the infringement attributed prescribes after two years, in accordance with Article 73.f) of the LOPDGDD, which qualifies the following conduct as serious:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall prescribe after two years, which involve a substantial violation of the articles mentioned therein and, in particular, the following: (...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

(...)

V

Sanction for the infringement of Article 32 of the GDPR

Article 83 “General conditions for the imposition of administrative fines” of the GDPR in its paragraph 7 establishes:

“Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

Likewise, Article 77, “Regime applicable to certain categories of controllers or processors,” of the LOPDGDD provides the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/11

“1. The regime established in this article shall apply to the processing for which they are responsible or processors:

a) ...

c) The General Administration of the State, the administrations of the autonomous communities, and the entities that comprise the Local Administration.

d) ...

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed.

The resolution shall be notified to the controller or processor of the processing, to the body to which it hierarchically depends, if applicable, and to the affected parties who have the status of interested parties, if applicable.

3. Without prejudice to the provisions of the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regime that is applicable.

Likewise, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is accredited,

the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the Official State Gazette or corresponding autonomous gazette.

4. The resolutions relating to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities.”

Therefore, with the infringement of Article 32 of the GDPR confirmed, it is appropriate to sanction the City Council with a warning.

VI

Adoption of measures

It is estimated that the City Council of Burgos shall, within 60 days, adopt the necessary technical and organizational measures to prevent the personal data of the recipients of the letters sent by the City Council of Burgos,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/11

remain visible to third parties not related to the recipient of the notification when the document does not have the acknowledgment of receipt attached, in accordance with the provisions established in the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...”. The imposition of this measure is compatible with the sanction consisting of a warning, as provided for in Article 83.2 of the GDPR.

It is noted that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on the CITY COUNCIL OF BURGOS, with NIF P0906100C, for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a warning sanction.

SECOND: TO NOTIFY this resolution to the CITY COUNCIL OF BURGOS.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions established in Article 77.5 of the LOPDGDD.

FOURTH: TO ORDER the CITY COUNCIL OF BURGOS, with NIF P0906100C, that pursuant to Article 58.2.d) of the GDPR, within a period of 60 days, prove that it has complied with the necessary technical and organizational measures to prevent the personal data of the recipients of the letters sent by the City Council of Burgos from being visible to third parties not related to the recipient of the notification when the document does not have the acknowledgment of receipt attached.

In accordance with the provisions established in Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions established in Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

11/11

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal.

If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with the documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension would be considered terminated.

938-010623

Mar España Martí
Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es